

ControlSift

Can a small language model tell
proof from paperwork?

AI assurance research for cybersecurity control evidence

MMC OPTION 4 / UN SDG 10

SYNTHETIC RESEARCH

ONE CONTROL. TWO VERY DIFFERENT ARTIFACTS.

**Privileged accounts must use
MFA.**

PAPERWORK

Policy document

“Privileged accounts are required to use MFA.”

PROOF

Operational export

Audit-period IAM rows show the privileged population,
MFA enrollment state, and review boundary.

The research question lives in the gap.

01 / PROBLEM IDENTIFICATION

Evidence that looks relevant is not always proof

Grounded in control-assessment guidance and real resource constraints.

NIST**Control assessment**

NIST SP 800-53A centers assessment on whether controls are implemented and achieve intended outcomes.

ACCESS**Capacity constraints**

NIST small-business guidance recognizes limited budgets, staffing, and specialist capacity.

WHY THIS MATTERS

ControlSift tests whether low-cost triage can focus human attention without lowering the assurance standard.

Sources: NIST SP 800-53A Rev. 5; NIST Small Business Cybersecurity Corner.

02 / RESEARCH & ANALYSIS

A benchmark designed to resist easy answers

Five labels, family-isolated splits, a sealed evaluation protocol, and one useful early failure.

SUFFICIENT

complete operational proof

PARTIAL

relevant, but materially incomplete

INSUFFICIENT

on-topic, not execution proof

IRRELEVANT

off-objective substance

CONTRADICTIONARY

contains a control-failure fact

SYNTHETIC CASES

~1,500

balanced five-class corpus

SPLITS

1000 / 200 / 200 / 100

train / val / test / challenge

PRIMARY METRIC

Macro F1

equal weight to every label

SEED

42

deterministic generation

EARLY FAILURE → BETTER RESEARCH

An earlier generator let TF-IDF reach 1.0 by exploiting lexical shortcuts. The benchmark was hardened, then the protocol was sealed before final model claims.

03 / SOLUTION DEVELOPMENT

A model ladder, not a one-model demo

Compare cheap baselines, prompting, and parameter-efficient fine-tuning — while preserving the version boundary.

CLASSICAL / DATASET v1.1.0

GEMMA 3 1B / DATASET v1.0.0

**VERSION BOUNDARY**

The experiments are real, but the classical and Gemma runs were completed on different benchmark versions. Cross-version values are descriptive receipts — not a controlled head-to-head leaderboard.

Why QLoRA? Memory-efficient fine-tuning makes adaptation possible on constrained hardware and free-tier GPU paths.

Sources: Dettmers et al., “QLoRA” (2023); Google DeepMind / Google, Gemma 3 model documentation.

04 / RESULTS

The useful finding is not an automatic AI win

Two internally valid result groups, one important output-reliability failure.

CLASSICAL / v1.1.0**Majority****0.067**

challenge 0.0667

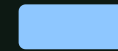
TF-IDF + LR**0.533**

challenge 0.5237

The hardened v1.1 lexical baseline is no longer trivial, but remains substantial.

GEMMA 3 1B / v1.0.0**Zero-shot****0.080**

parse success 76.0%

Few-shot**0.137**

parse success 98.5% • strongest Gemma rung

QLoRA**0.083**

parse success 43.5% • did not beat few-shot

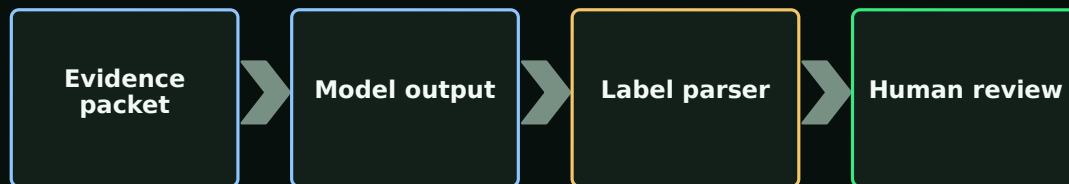
Defensible conclusion

Few-shot beats QLoRA within Gemma v1.0; fine-tuning did not automatically improve the task. Cross-version classical-vs-Gemma ranking is not claimed.

Assurance includes the failure modes

The project documents how the model can fail, who remains accountable, and what the artifact is not allowed to claim.

FAILURE LAB / OUTPUT PATH



QLoRA parse success: 43.5%

Malformed generations count as errors. They are not silently remapped to a favorable label.

GOVERNANCE ARTIFACTS

DATA CARD

what the benchmark is

MODEL CARD

what the model is for

RISK REGISTER

what can go wrong

INTENDED USE

what is allowed

LIMITATIONS

what is not proven

FAILURE LAB

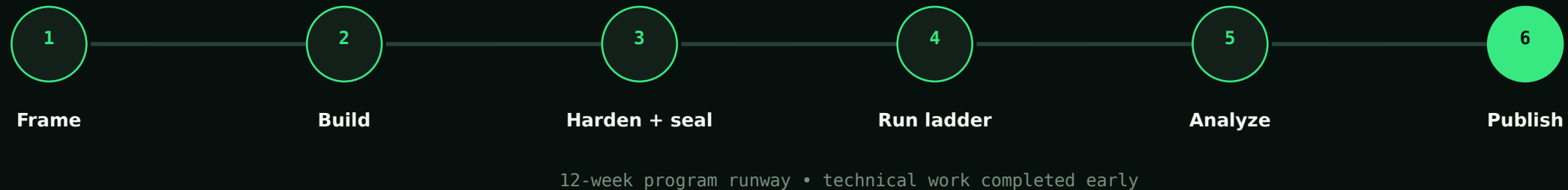
where it breaks

**Human judgment remains
authoritative.**

06 / IMPLEMENTATION PLAN

Built to be practical, inspectable, and reproducible

A six-phase path, modest infrastructure, explicit risks, and clear production boundaries.

**BUILD**

Resources

Python • scikit-learn • Gemma 3 •
Hugging Face • Kaggle / Colab • GitHub
Pages

RISK

Risks managed

Leakage • lexical shortcuts • test tuning •
fabricated metrics • secret exposure •
automation bias

IMPACT

Viability

Practical: low-cost baseline
Sustainable: synthetic + open
Scalable: research / training
Production: validation required

07 / CONCLUSION

A useful AI project does not need an AI victory

The value is in the evidence, the boundaries, and the decision the experiment supports.

1

Do not deploy it as audit autopilot.

Human authority and governed validation remain mandatory.

2

Few-shot beat QLoRA within the Gemma v1.0 runs.

Fine-tuning did not automatically improve this evidence task.

3

The negative result is still a result.

ControlSift preserves the receipts, failure modes, and claim boundaries.

[INSPECT THE FULL ARTIFACT](#)jtflack-grc.github.io/controlstift/

[Report](#) • [sources](#) • [results](#) • [Failure Lab](#) •
[assurance](#) • [reproduce](#)

External grounding and full bibliography are published in the ControlSift capstone research-sources page.